

Rapport de Pentesting – OWASP Juice Shop

1. Introduction

Objectif du projet :

Ce travail consiste à analyser la sécurité de l'application **OWASP Juice Shop**, une application web volontairement vulnérable utilisée pour l'apprentissage de la sécurité applicative. L'objectif est d'identifier plusieurs vulnérabilités, de démontrer leur exploitation et d'analyser leur impact sur la sécurité du système.

- environnement utilisé : **Kali Linux**
- outils utilisés : **Nmap, Gobuster, Burp Suite, DevTools**

2. Environnement de test

Application cible :

- OWASP Juice Shop
- URL : http://localhost:3000

Machine d'attaques :

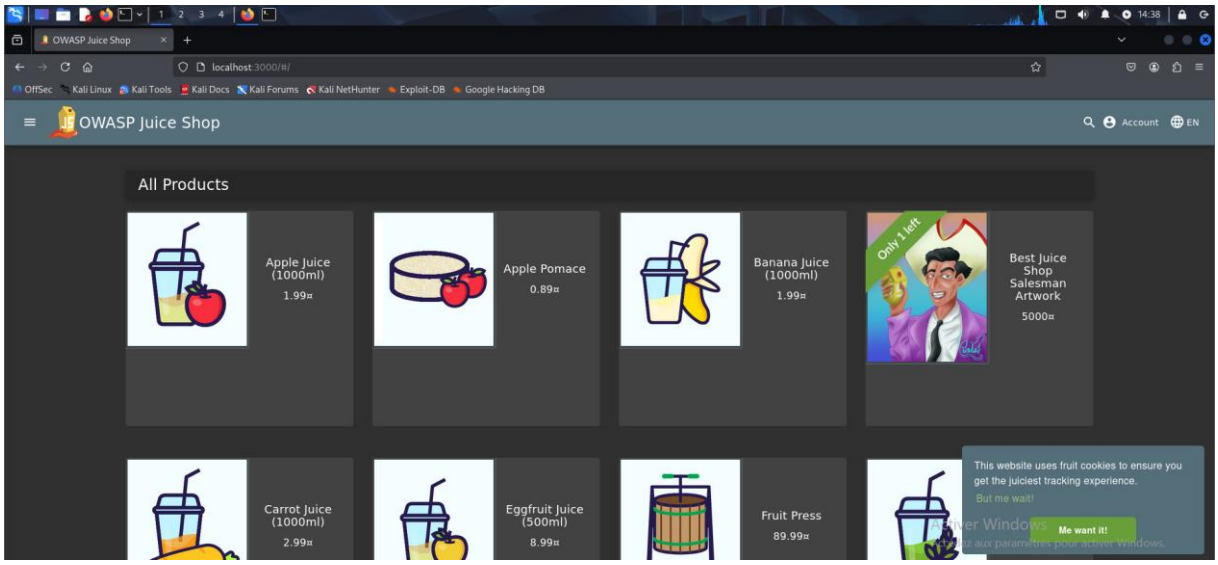
- Kali Linux

Outils utilisés :

- Nmap
- Gobuster
- Dirsearch
- Whatweb
- Burp Suite
- Firefox DevTools
- JWT-tool
- JWT.io

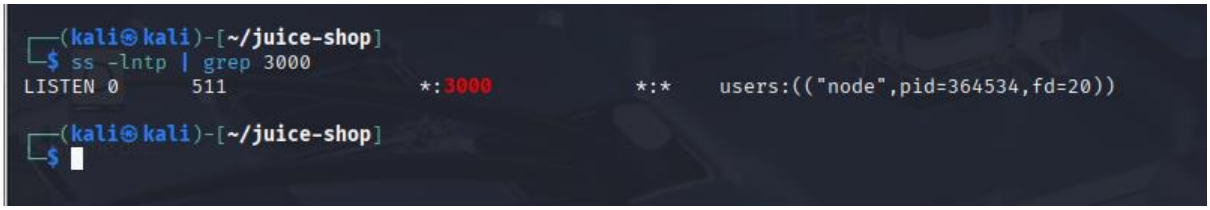
3. Phase de reconnaissance

Vérifions que l'app est accessible



Dans un terminal, vérifions que le port 3000 est ouvert :

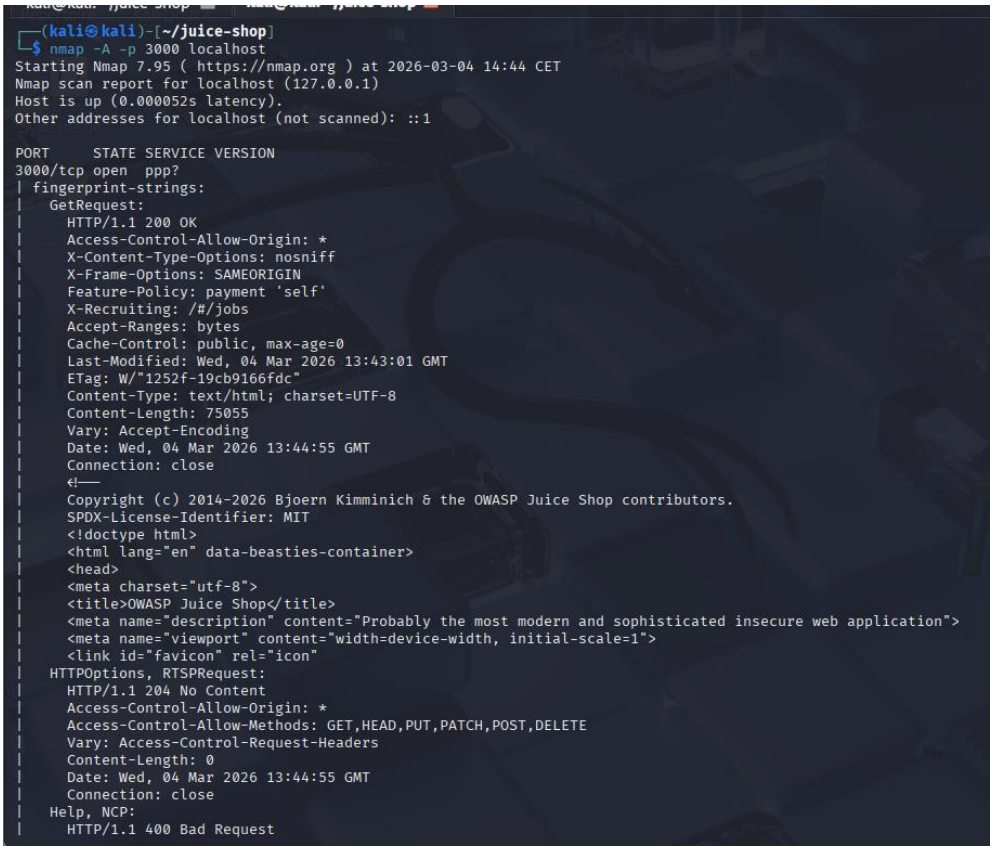
ss -lntp | grep 3000



3.1 Découverte du service (Nmap+whatweb)

Commande utilisée :

nmap -A -p 3000 localhost



```
┌──(kali㉿kali)-[~/juice-shop]
└─$ nmap -A -p 3000 localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-04 14:44 CET
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000052s latency).
Other addresses for localhost (not scanned): ::1

PORT     STATE SERVICE VERSION
3000/tcp open  ppp?
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 200 OK
|     Access-Control-Allow-Origin: *
|     X-Content-Type-Options: nosniff
|     X-Frame-Options: SAMEORIGIN
|     Feature-Policy: payment 'self'
|     X-Recruiting: /#/jobs
|     Accept-Ranges: bytes
|     Cache-Control: public, max-age=0
|     Last-Modified: Wed, 04 Mar 2026 13:43:01 GMT
|     ETag: W/"1252f-19cb9166fdc"
|     Content-Type: text/html; charset=UTF-8
|     Content-Length: 75055
|     Vary: Accept-Encoding
|     Date: Wed, 04 Mar 2026 13:44:55 GMT
|     Connection: close
|     <!--
|     Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
|     SPDX-License-Identifier: MIT
|     -->
|     <!doctype html>
|     <html lang="en" data-beasties-container>
|     <head>
|     <meta charset="utf-8">
|     <title>OWASP Juice Shop</title>
|     <meta name="description" content="Probably the most modern and sophisticated insecure web application">
|     <meta name="viewport" content="width=device-width, initial-scale=1">
|     <link id="favicon" rel="icon"
|   HTTPOptions, RTSPRequest:
|     HTTP/1.1 204 No Content
|     Access-Control-Allow-Origin: *
|     Access-Control-Allow-Methods: GET,HEAD,PUT,PATCH,POST,DELETE
|     Vary: Access-Control-Request-Headers
|     Content-Length: 0
|     Date: Wed, 04 Mar 2026 13:44:55 GMT
|     Connection: close
|   Help, NCP:
|     HTTP/1.1 400 Bad Request
```

Commande utilisée :

Whatweb http://localhost:3000



```
┌──(chaima㉿kali)-[~]
└─$ whatweb http://localhost:3000
http://localhost:3000 [200 OK] HTML5, IP[::1], JQuery[2.2.4], Script[module], Title[OWASP Juice Shop], UncommonHeaders[access-control-allow-origin,x-content-type-options,feature-policy,x-recruiting], X-Frame-Options[SAMEORIGIN]

┌──(chaima㉿kali)-[~]
└─$
```

Résultat :

- Port ouvert : **3000**
- Service : **HTTP**
- Technologie : **Node.js / Express**

3.2 Enumeration des répertoires

Outil utilisé : **Gobuster**

Commande :

gobuster dir -u http://localhost:3000 -w /usr/share/wordlists/dirb/common.txt



```
┌──(chaima㉿kali)-[~]
└─$ gobuster dir -u http://localhost:3000 -w /usr/share/wordlists/dirb/common.txt --exclude-length 75055
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://localhost:3000
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] Exclude Length:          75055
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/api                 (Status: 500) [Size: 3017]
/apis                (Status: 500) [Size: 3019]
/assets              (Status: 301) [Size: 156] [--> /assets/]
/ftp                 (Status: 200) [Size: 11297]
/profile             (Status: 500) [Size: 1043]
/promotion           (Status: 200) [Size: 6586]
/redirect            (Status: 500) [Size: 3119]
/rest                (Status: 500) [Size: 3019]
/restaurants         (Status: 500) [Size: 3033]
/restored            (Status: 500) [Size: 3027]
/restore             (Status: 500) [Size: 3025]
/restricted          (Status: 500) [Size: 3031]
/robots.txt          (Status: 200) [Size: 28]
/Video               (Status: 200) [Size: 10075518]
/video               (Status: 200) [Size: 10075518]
Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
===============================================================
```

Outil utilisé : **Dirsearch**

Commande :

dirsearch -u http://localhost:3000 -w /usr/share/wordlists/dirb/common.txt

```
┌──(chaima㉿kali)-[~]
└─$ dirsearch -u http://localhost:3000 -w /usr/share/wordlists/dirb/common.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 4613

Output File: /home/chaima/reports/http_localhost_3000/_26-03-07_13-44-46.txt

Target: http://localhost:3000/

[13:44:46] Starting:
[13:45:03] 500 -    3KB - /api
[13:45:03] 500 -    3KB - /apis
[13:45:07] 301 -  156B  - /assets  →  /assets/
[13:46:23] 200 -   11KB - /ftp
[13:48:43] 500 -    1KB - /profile
[13:48:45] 200 -    6KB - /promotion
[13:49:00] 500 -    3KB - /redirect
[13:49:10] 500 -    3KB - /restored
[13:49:10] 500 -    3KB - /rest
[13:49:10] 500 -    3KB - /restaurants
[13:49:10] 500 -    3KB - /restore
[13:49:10] 500 -    3KB - /restricted
[13:49:11] 200 -   28B  - /robots.txt
[13:51:07] 200 -   10MB - /Video
[13:51:07] 200 -   10MB - /video

Task Completed
```

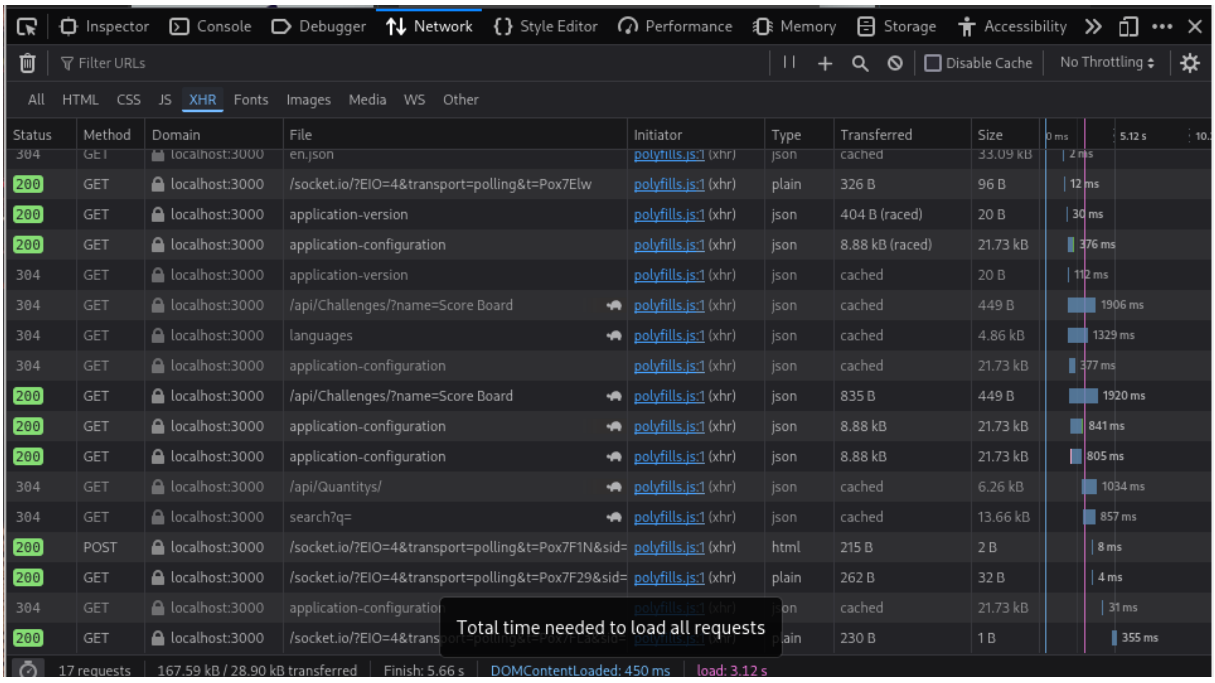
Répertoires trouvés :

- /ftp
- /rest
- /api

3.3 Analyse des endpoints

L'analyse des requêtes HTTP a été réalisée avec :

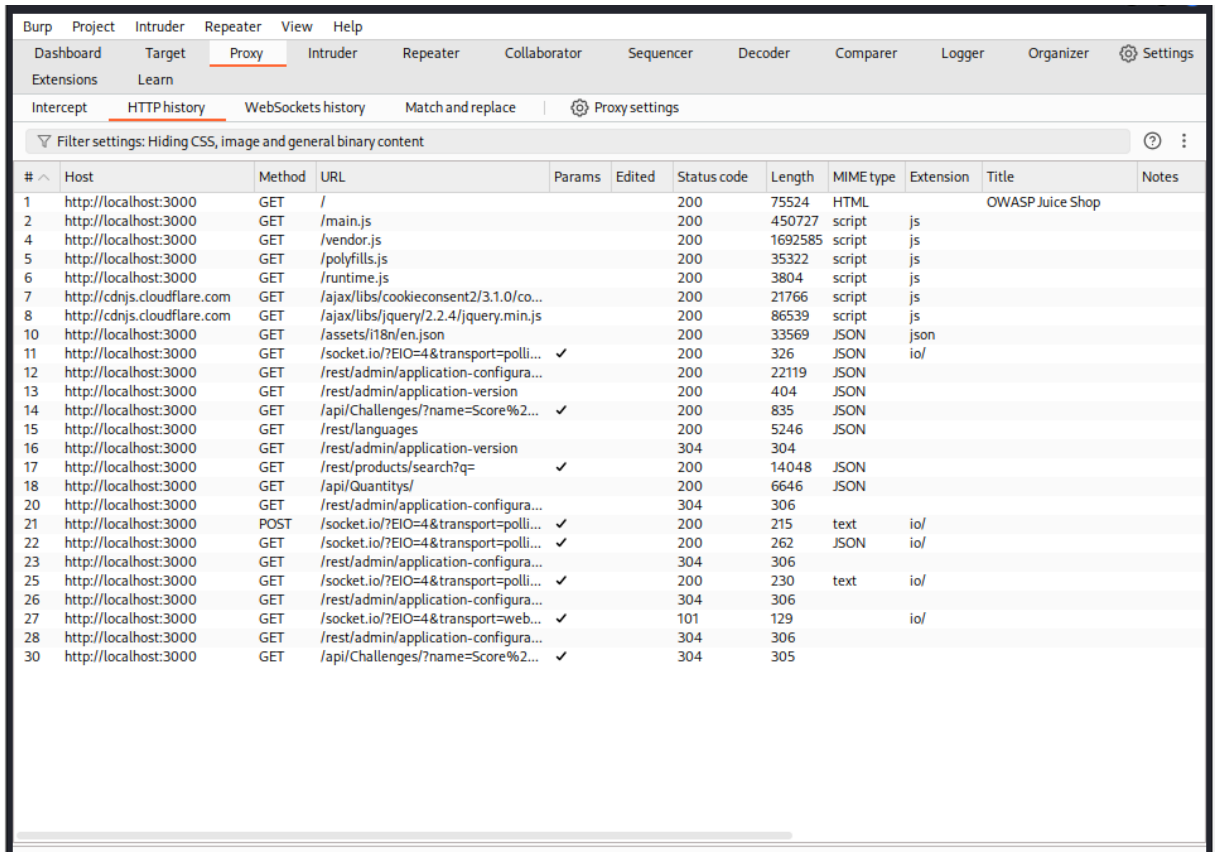
- **DevTools**
- **Burp Suite**



API découvertes :

Endpoint	Méthodes	Description
/rest/products	GET	Liste des produits
/rest/products/search	GET	Recherche
/rest/user/login	POST	Authentification
/api/users	POST	Création de compte

BurpSuite : intercepter et lister tous les endpoints



Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Settings

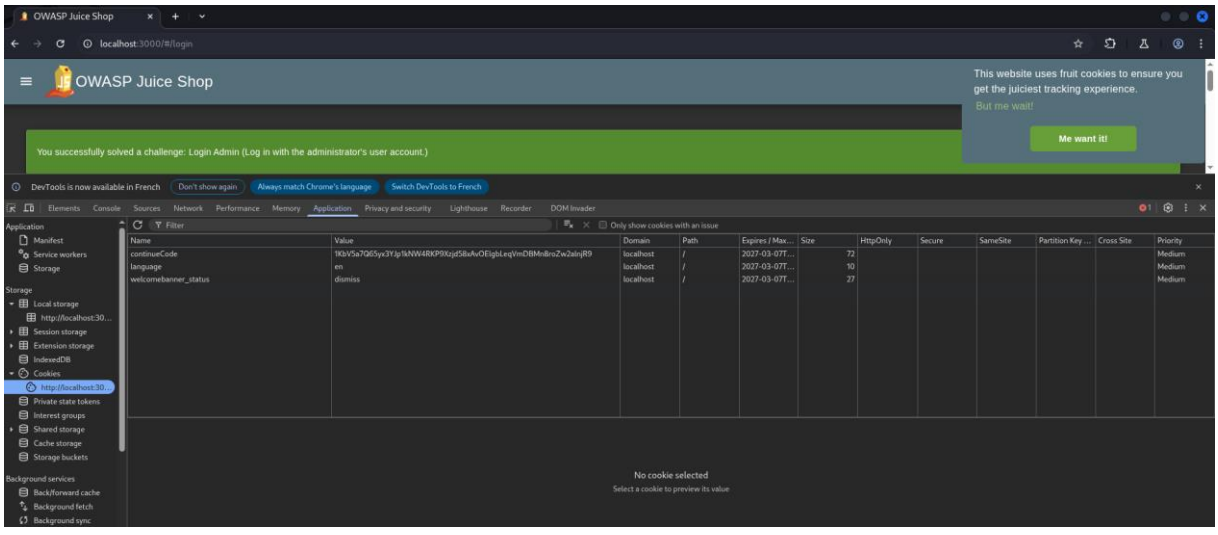
Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes
1	http://localhost:3000	GET	/			200	75524	HTML		OWASP Juice Shop	
2	http://localhost:3000	GET	/main.js			200	450727	script	js		
4	http://localhost:3000	GET	/vendor.js			200	1692585	script	js		
5	http://localhost:3000	GET	/polyfills.js			200	35322	script	js		
6	http://localhost:3000	GET	/runtime.js			200	3804	script	js		
7	http://cdnjs.cloudflare.com	GET	/ajax/libs/cookieconsent2/3.1.0/co...			200	21766	script	js		
8	http://cdnjs.cloudflare.com	GET	/ajax/libs/jquery/2.2.4/jquery.min.js			200	86539	script	js		
10	http://localhost:3000	GET	/assets/i18n/en.json			200	33569	JSON	json		
11	http://localhost:3000	GET	/socket.io/?EIO=4&transport=polli...	✓		200	326	JSON	io/		
12	http://localhost:3000	GET	/rest/admin/application-configura...			200	22119	JSON			
13	http://localhost:3000	GET	/rest/admin/application-version			200	404	JSON			
14	http://localhost:3000	GET	/api/Challenges/?name=Score%2...	✓		200	835	JSON			
15	http://localhost:3000	GET	/rest/languages			200	5246	JSON			
16	http://localhost:3000	GET	/rest/admin/application-version			304	304				
17	http://localhost:3000	GET	/rest/products/search?q=	✓		200	14048	JSON			
18	http://localhost:3000	GET	/api/Quantitys/			200	6646	JSON			
20	http://localhost:3000	GET	/rest/admin/application-configura...			304	306				
21	http://localhost:3000	POST	/socket.io/?EIO=4&transport=polli...	✓		200	215	text	io/		
22	http://localhost:3000	GET	/socket.io/?EIO=4&transport=polli...	✓		200	262	JSON	io/		
23	http://localhost:3000	GET	/rest/admin/application-configura...			304	306				
25	http://localhost:3000	GET	/socket.io/?EIO=4&transport=polli...	✓		200	230	text	io/		
26	http://localhost:3000	GET	/rest/admin/application-configura...			304	306				
27	http://localhost:3000	GET	/socket.io/?EIO=4&transport=web...	✓		101	129		io/		
28	http://localhost:3000	GET	/rest/admin/application-configura...			304	306				
30	http://localhost:3000	GET	/api/Challenges/?name=Score%2...	✓		304	305				

3.3 Analyse des sessions JWT



OWASP Juice Shop

localhost:3000/#/login

OWASP Juice Shop

This website uses fruit cookies to ensure you get the juiciest tracking experience.

But me wait!

Me want it!

You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)

DevTools is now available in French

Application

Manifest

Service workers

Storage

Local storage

Session storage

Extension storage

IndexedDB

Cookies

Private state tokens

Interest groups

Shared storage

Cache storage

Storage buckets

Background services

Back/forward cache

Background fetch

Background sync

Name	Value	Domain	Path	Expires / Max...	Size	HttpOnly	Secure	SameSite	Partition Key ...	Cross Site	Priority
continueCode	1Kb/V5a7Q65yv3YJp1kNW4RKP9IXzjd5BxAvOElgbLeqVmDBMnBroZw2alnjR9	localhost	/	2027-03-07T...	72						Medium
language	en	localhost	/	2027-03-07T...	10						Medium
welcomebanner_status	dismiss	localhost	/	2027-03-07T...	27						Medium

No cookie selected

Select a cookie to preview its value

L'application utilise un **JSON Web Token (JWT)** pour gérer la session utilisateur.

Le token a été décodé avec l'outil :

jwt-tool

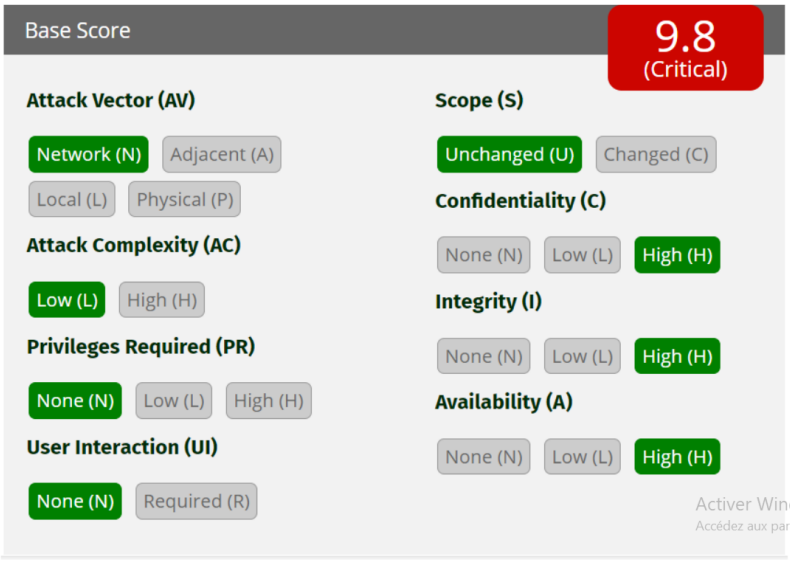
Cela permet d'observer le contenu du **payload** :

- email utilisateur
- rôle
- identifiant



4. Vulnérabilités exploitées

4.1 Injection SQL (Authentication Bypass)



Description :

L'application Juice Shop est vulnérable à une **SQL Injection dans le formulaire de connexion**. Les entrées utilisateur (email et mot de passe) sont envoyées au serveur sans validation suffisante, ce qui permet d'injecter du code SQL malveillant.

Exploitation :

Payload utilisé :

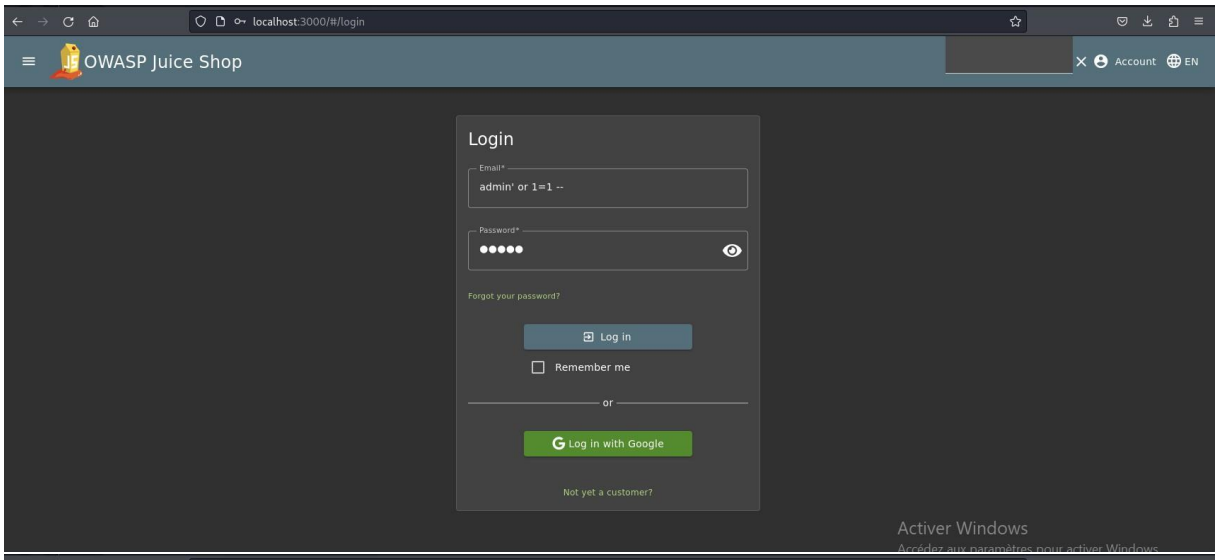
```
' OR 1=1--
```

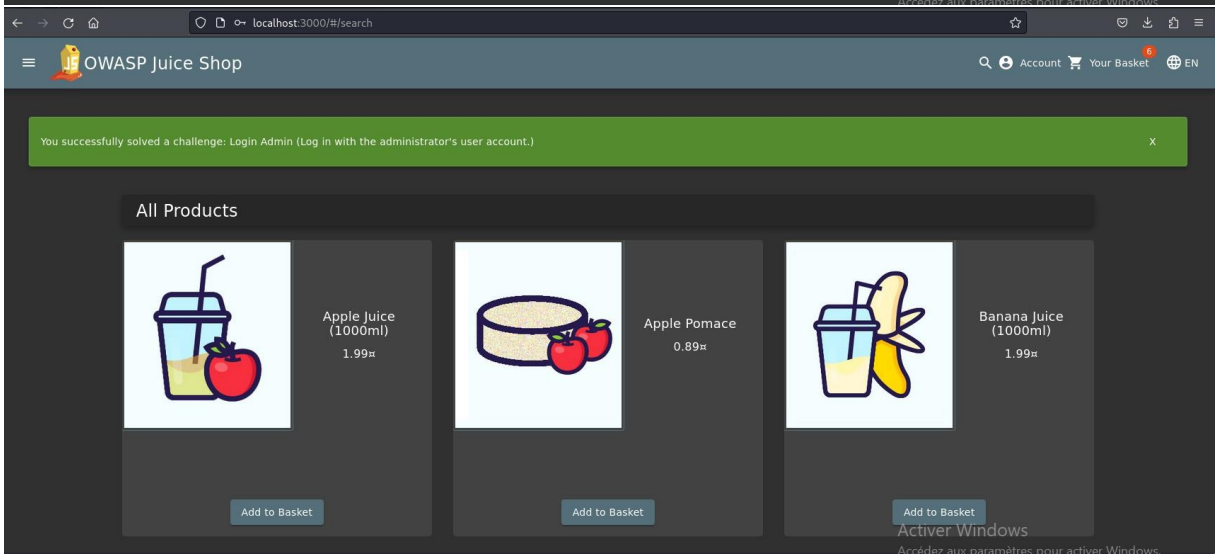
Ce payload modifie la requête SQL et rend la condition d'authentification toujours vraie.

Résultat :
L'attaquant peut contourner le système d'authentification et obtenir un accès au compte administrateur sans connaître le mot de passe.

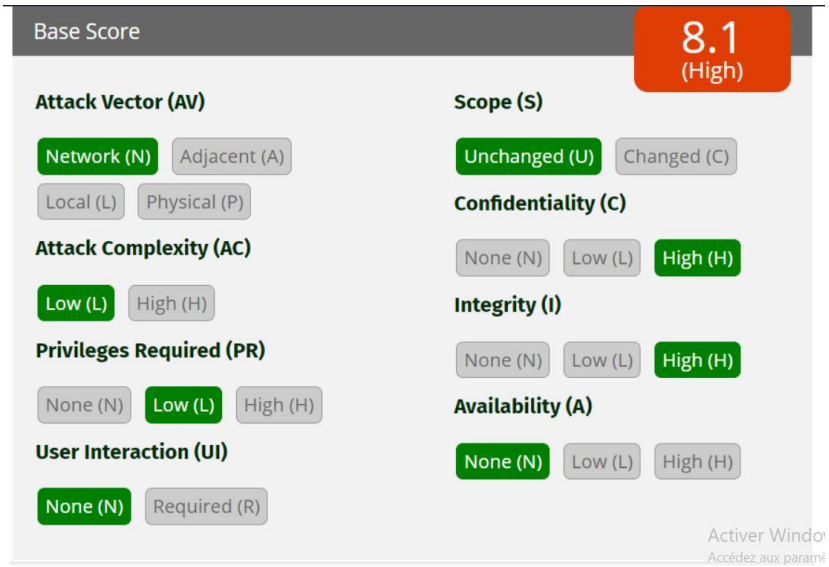
Impact :

- accès non autorisé au compte admin
- manipulation des données de l'application
- compromission complète du système


localhost:3000/#/login
OWASP Juice Shop
Account
EN
Login
Email*
admin' or 1=1 --
Password*
Forgot your password?
Log in
Remember me
or
Log in with Google
Not yet a customer?
Activer Windows


localhost:3000/#/search
OWASP Juice Shop
Account
Your Basket
EN
You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)
All Products
Apple Juice (1000ml)
1.99¤
Add to Basket
Apple Pomace
0.89¤
Add to Basket
Banana Juice (1000ml)
1.99¤
Add to Basket
Activer Windows

4.2 Cross Site Scripting (XSS)



Description :

La barre de recherche de Juice Shop ne filtre pas correctement les entrées utilisateur. Un attaquant peut injecter du code JavaScript qui sera exécuté dans le navigateur de la victime.

Payload :

<img src=x onerror=alert('XSS')>

URL :

http://localhost:3000/#/search?q=<iframe src="javascript:alert('XSS')">

Résultat

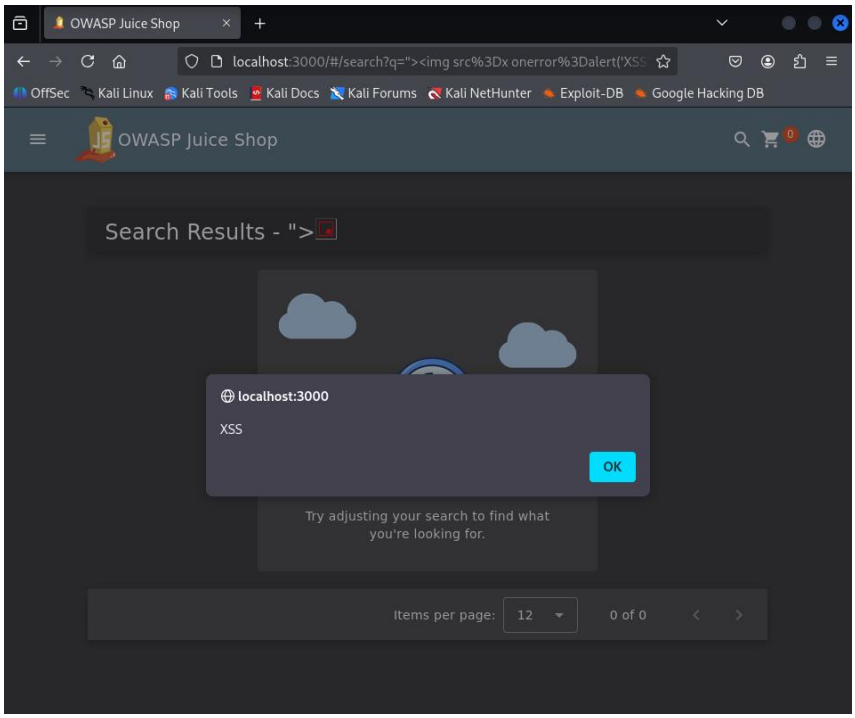
Le navigateur exécute le script JavaScript injecté.

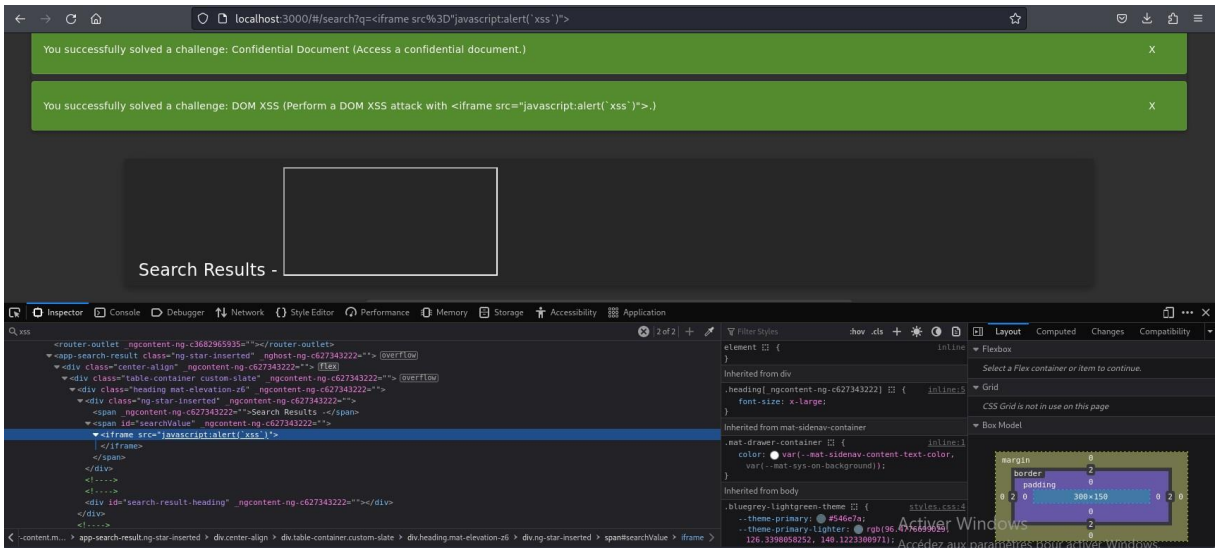
Impact

- vol de cookies
- redirection vers un site malveillant
- exécution de code dans le navigateur de la victime

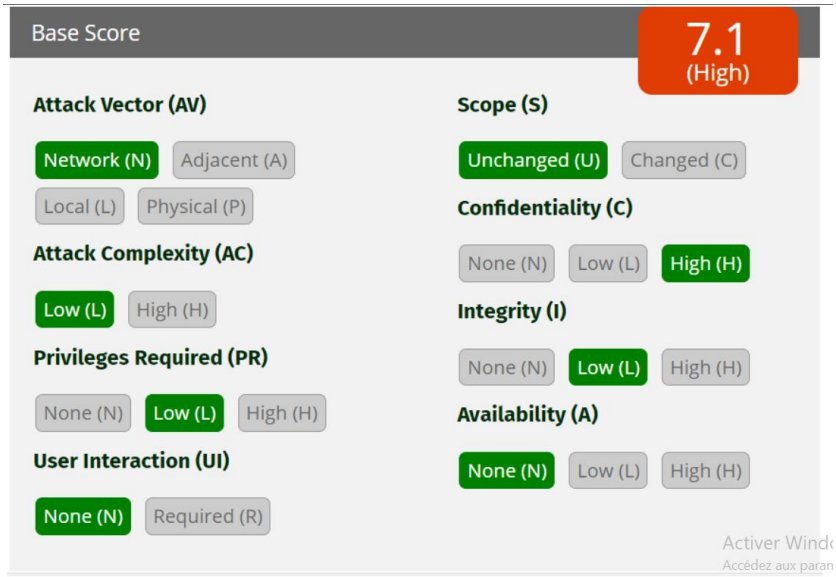
Recommandations

- encoder les sorties HTML
- utiliser **Content Security Policy**
- filtrer les entrées utilisateur





4.3 Accès à des fichiers sensibles



Description

Juice Shop contient un répertoire **/ftp** accessible publiquement.
Ce dossier expose des fichiers internes de l'entreprise.

Exemple :

http://localhost:3000/ftp/acquisitions.md

Résultat

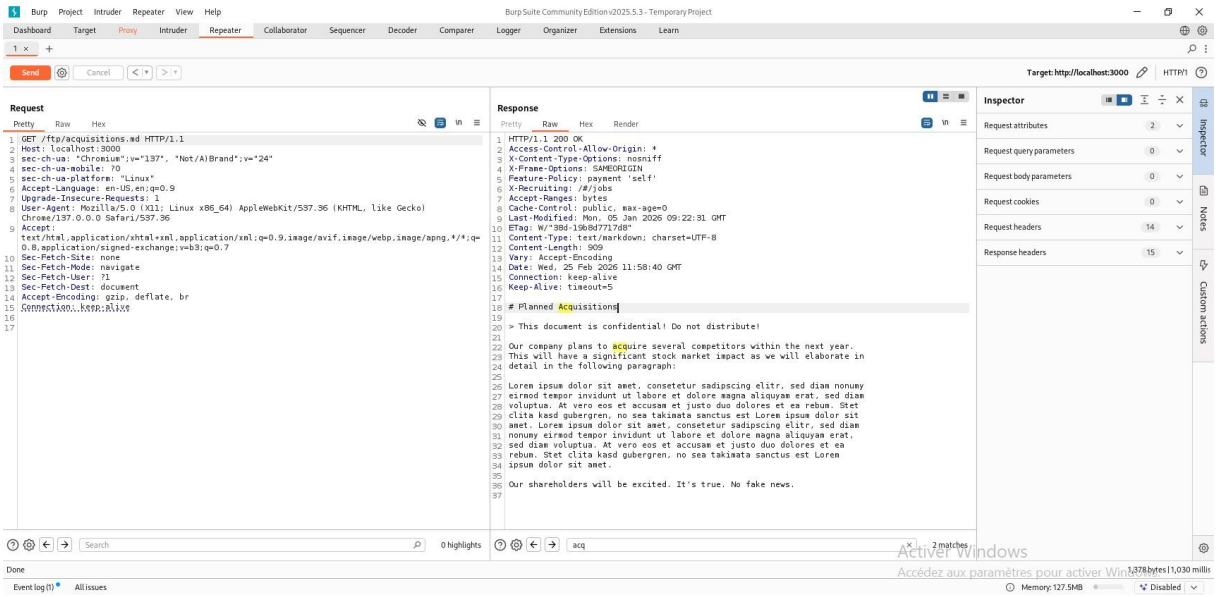
L'attaquant peut lire des informations internes concernant les acquisitions de l'entreprise.

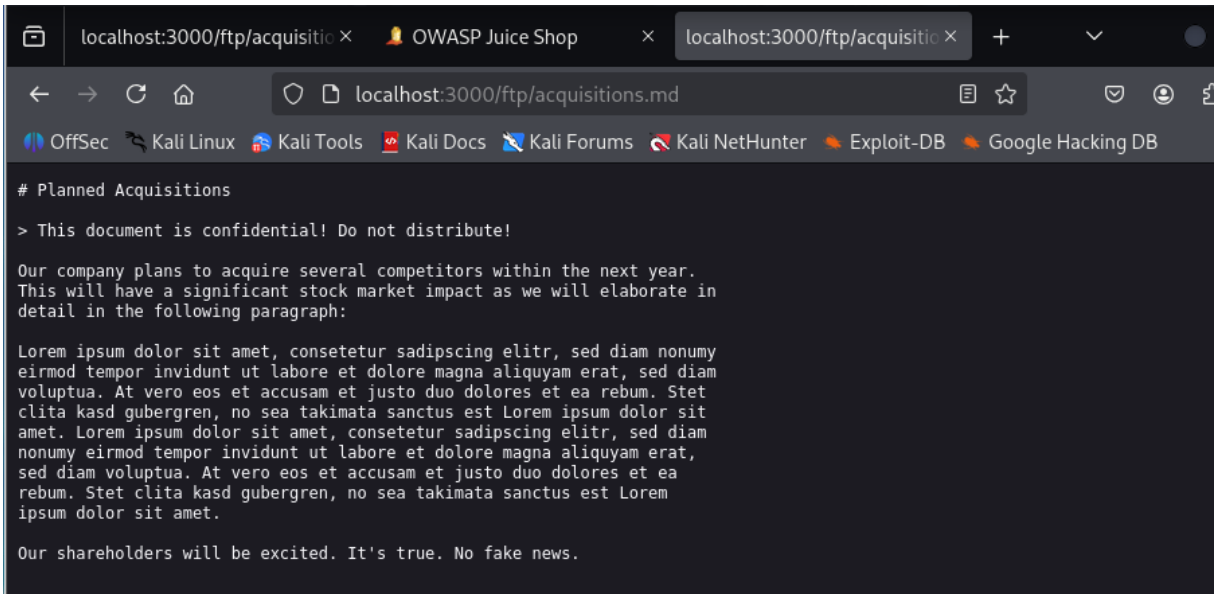
Impact

- fuite d'informations internes
- aide à préparer des attaques ciblées
- exposition de données sensibles

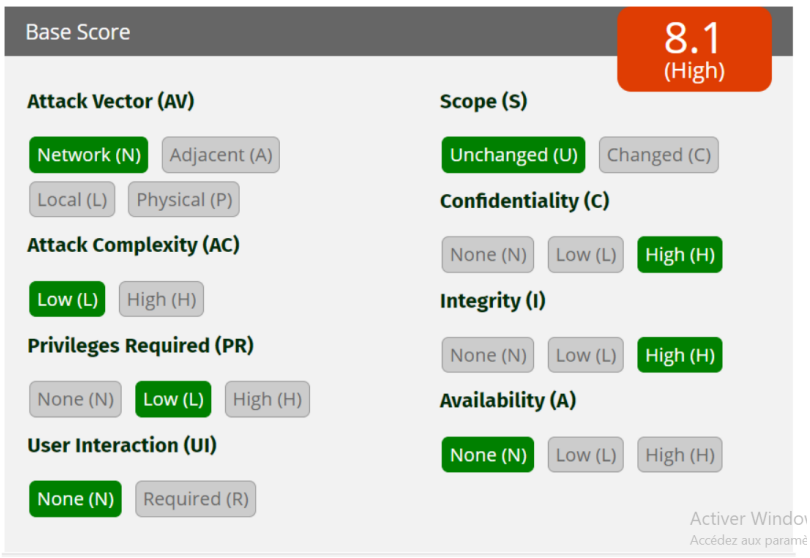
Recommandations

- restreindre l'accès aux fichiers
- supprimer les fichiers sensibles du serveur
- mettre en place des contrôles d'accès


Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2025.5.3 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Send Cancel
Target: http://localhost:3000
HTTP/1
Request
Pretty Raw Hex
GET /ftp/acquisitions.md HTTP/1.1
Host: localhost:3000
sec-ch-ua: "Chromium";v="137", "Not/A)Brand";v="24"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Linux"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Response
Pretty Raw Hex Render
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Mon, 05 Jan 2026 09:22:31 GMT
ETag: W/"38d-19b8d7717d8"
Content-Type: text/markdown; charset=UTF-8
Content-Length: 909
Vary: Accept-Encoding
Date: Wed, 25 Feb 2026 11:58:40 GMT
Connection: keep-alive
Keep-Alive: timeout=5
Planned Acquisitions
> This document is confidential! Do not distribute!
Our company plans to acquire several competitors within the next year.
This will have a significant stock market impact as we will elaborate in detail in the following paragraph:
Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet.
Our shareholders will be excited. It's true. No fake news.
Inspector
Request attributes
Request query parameters
Request body parameters
Request cookies
Request headers
Response headers
Inspector
Notes
Custom actions
Search
0 highlights
acq
2 matches
Done
1,378 bytes | 1,030 millis
Event log (1)
All issues
Memory: 127.5MB
Disabled


localhost:3000/ftp/acquisitic
OWASP Juice Shop
localhost:3000/ftp/acquisitic
localhost:3000/ftp/acquisitions.md
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Planned Acquisitions
> This document is confidential! Do not distribute!
Our company plans to acquire several competitors within the next year.
This will have a significant stock market impact as we will elaborate in detail in the following paragraph:
Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet.
Our shareholders will be excited. It's true. No fake news.

4.4 Broken Access Control



Description :

Juice Shop présente une vulnérabilité de **Broken Access Control** où l'application ne vérifie pas correctement les permissions d'accès aux ressources.
Un utilisateur peut modifier l'identifiant dans une requête pour accéder aux données d'un autre utilisateur.

Exploitation :

Dans l'API :

```
/rest/basket/1
/rest/basket/2
```

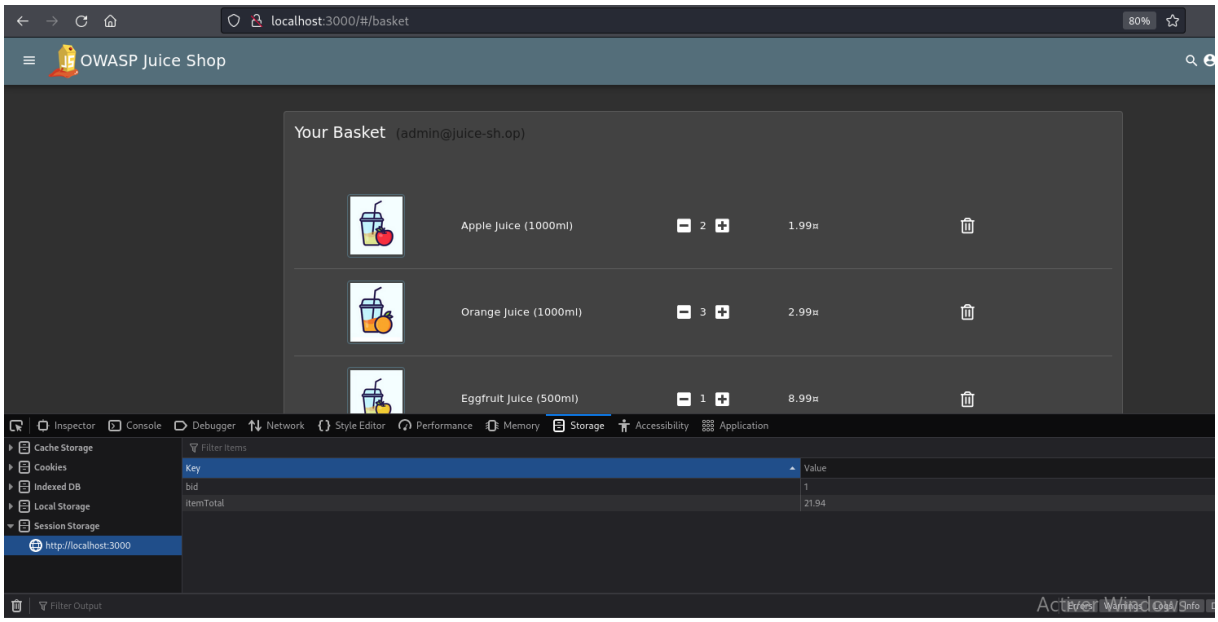
En modifiant simplement l'ID, un utilisateur peut accéder au panier d'un autre utilisateur.

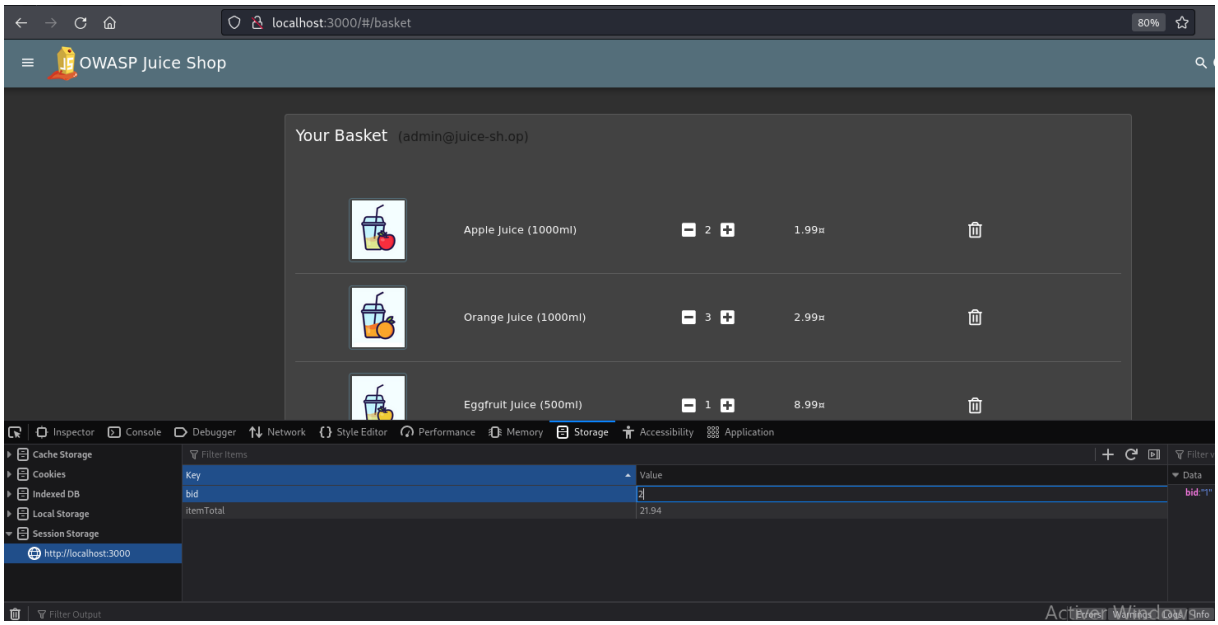
Impact :

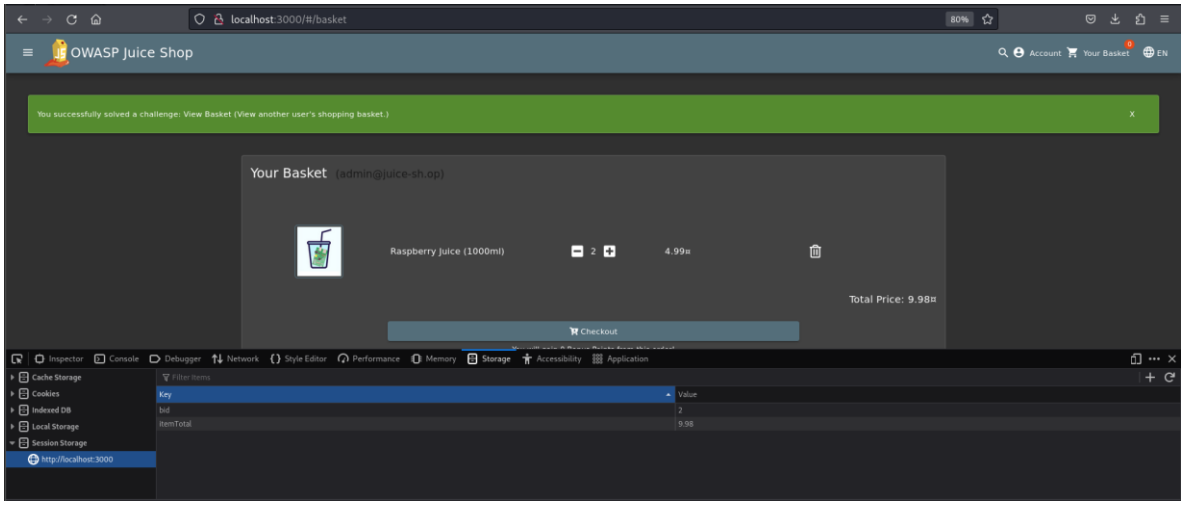
- accès aux données d'autres utilisateurs
- fuite d'informations personnelles
- violation de la confidentialité

Recommandations :

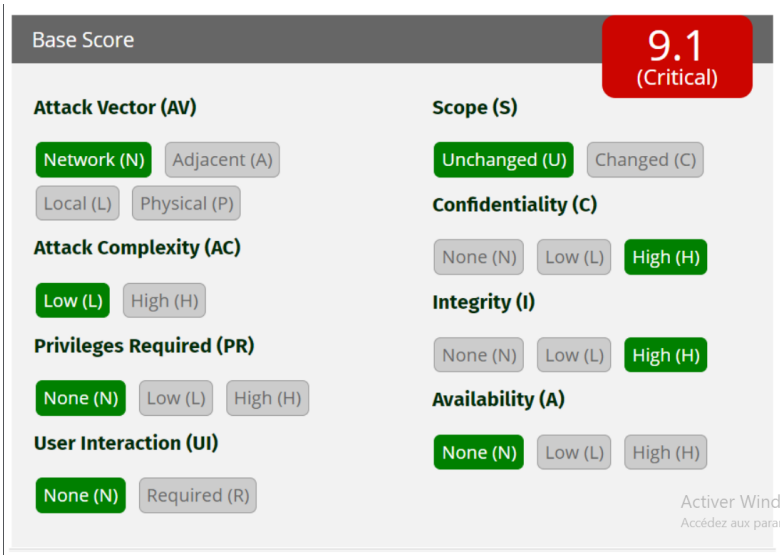
- vérifier les permissions côté serveur
- associer chaque ressource à l'utilisateur authentifié


localhost:3000/#/basket
OWASP Juice Shop
Your Basket (admin@juice-sh.op)
Apple Juice (1000ml) 2 1.99¤
Orange Juice (1000ml) 3 2.99¤
Eggfruit Juice (500ml) 1 8.99¤
Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application
Cache Storage
Cookies
Indexed DB
Local Storage
Session Storage
http://localhost:3000
Key Value
bid 1
itemTotal 21.94


localhost:3000/#/basket
OWASP Juice Shop
Your Basket (admin@juice-sh.op)
Apple Juice (1000ml) 2 1.99¤
Orange Juice (1000ml) 3 2.99¤
Eggfruit Juice (500ml) 1 8.99¤
Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application
Cache Storage
Cookies
Indexed DB
Local Storage
Session Storage
http://localhost:3000
Key Value
bid 2
itemTotal 21.94


localhost:3000/#/basket
OWASP Juice Shop
You successfully solved a challenge: View Basket (View another user's shopping basket.)
Your Basket (admin@juice-sh.op)
Raspberry Juice (1000ml) 2 4.99¤
Total Price: 9.98¤
Checkout
Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application
Cache Storage
Cookies
Indexed DB
Local Storage
Session Storage
http://localhost:3000
Key Value
bid 2
itemTotal 9.98

4.5 Insecure Design and Implementation of JWT



Description :

Cette vulnérabilité se produit lorsque l'application accepte un **JSON Web Token (JWT)** sans vérifier correctement sa signature.
Un attaquant peut modifier l'en-tête du token et définir l'algorithme sur `alg: none`, ce qui signifie que le token n'est pas signé. Si l'application ne vérifie pas cette signature, elle peut accepter ce token falsifié comme valide.

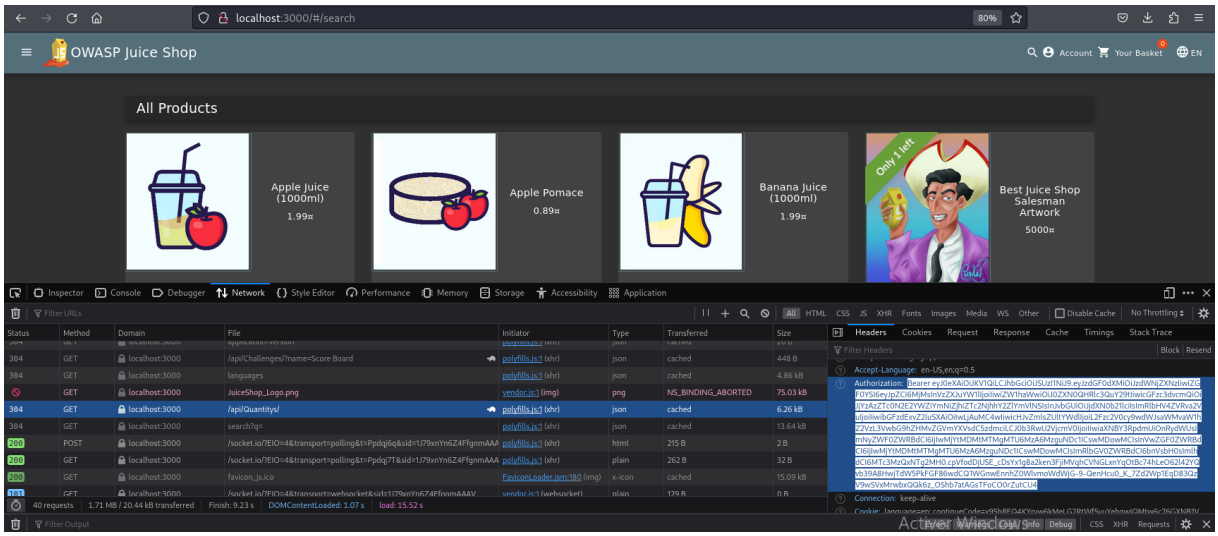
Résultat :

Le token JWT a été décodé et modifié avec JWT.io en changeant l'algorithme en none et en définissant l'utilisateur `jwtn3d@juice-sh.op` dans le payload. Ensuite, la requête HTTP a été interceptée avec Burp Suite et le token original a été remplacé par le token falsifié. L'application a accepté ce token et a authentifié l'attaquant comme cet utilisateur.

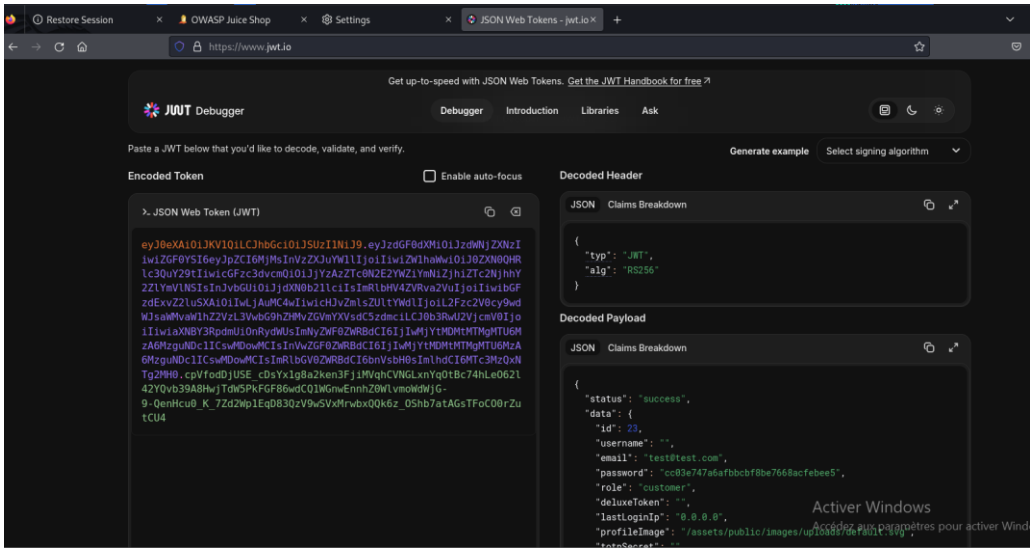
Impact :

Cette vulnérabilité permet le **contournement du mécanisme d'authentification**, l'**usurpation d'identité d'utilisateur** et l'accès non autorisé aux fonctionnalités protégées de l'application. Elle peut conduire à une compromission du système si un attaquant génère des tokens pour accéder à différents comptes

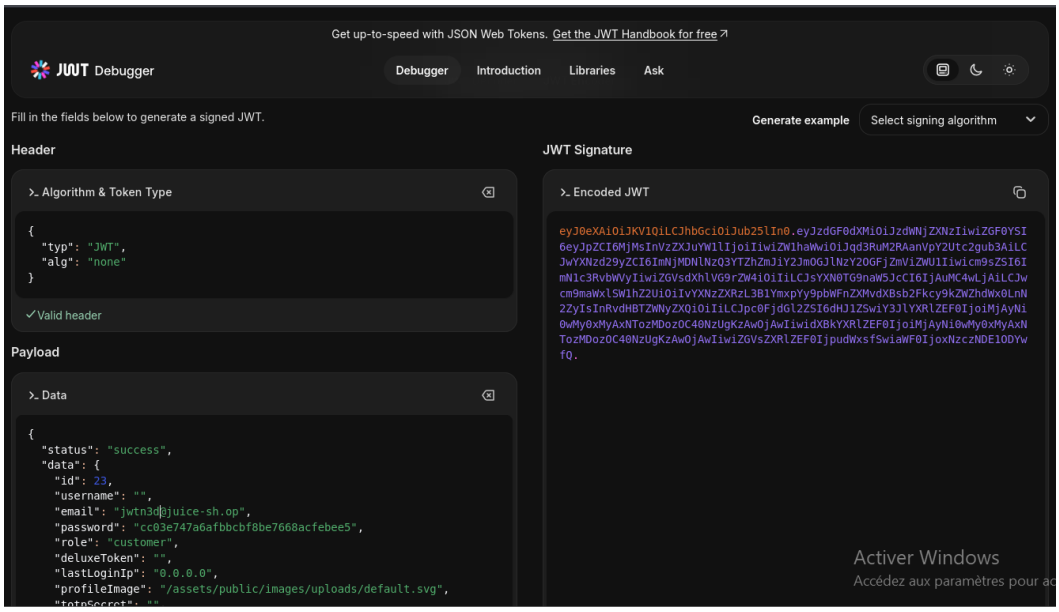
Le token JWT original a été récupéré après connexion:



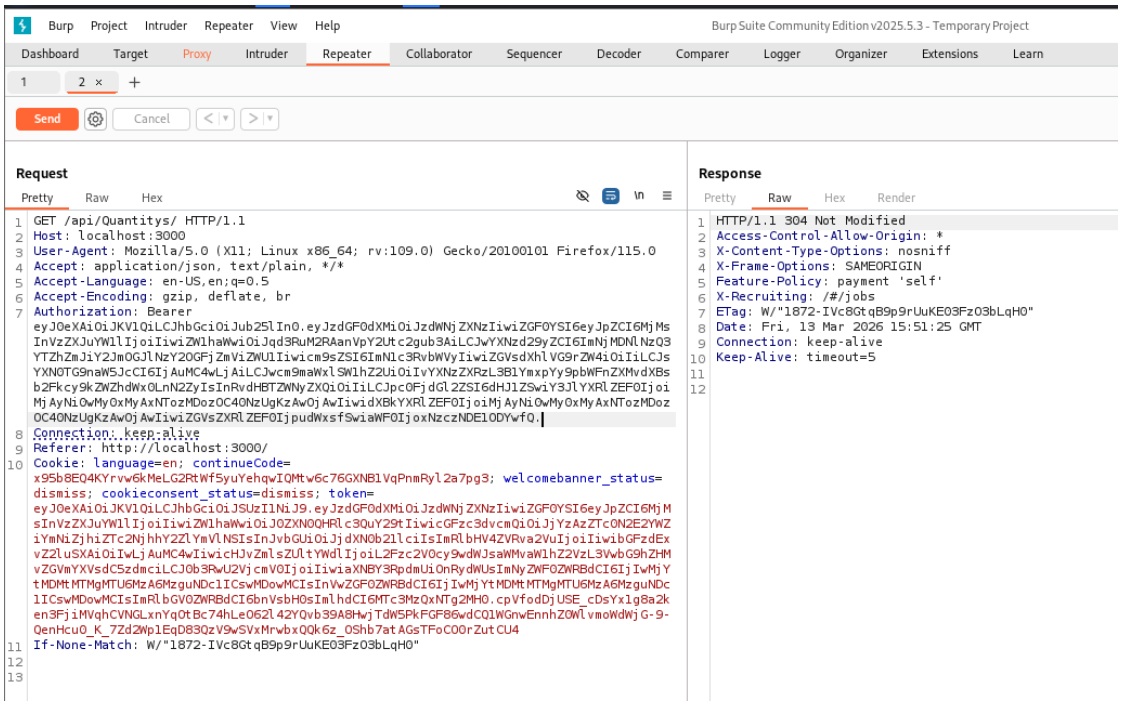
Le token a été **copié dans le site JWT.io** pour le décoder et modifier son contenu:



Le **header a été modifié pour utiliser `alg: none`** et le payload a été ajusté pour impersonner l'utilisateur `jwtn3d@juice-sh.op`:

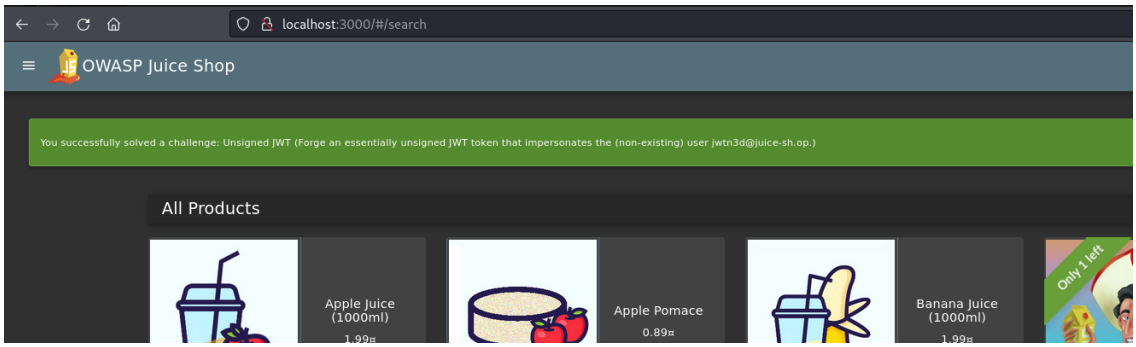


À l'aide de Burp Suite, la requête HTTP a été interceptée et le **token original dans l'en-tête Authorization** a été remplacé par le token falsifié:



Résultat :

L'application a accepté le **JWT non signé**, permettant une authentification avec l'utilisateur falsifié.



5. Consignes de sécurité (Recommandations)

Afin d'améliorer la sécurité de l'application web et de réduire les risques d'exploitation des vulnérabilités identifiées, plusieurs mesures de sécurité doivent être mises en œuvre.

Tout d'abord, il est essentiel de **valider et filtrer toutes les entrées utilisateur**. Les données saisies par les utilisateurs doivent être contrôlées afin d'empêcher l'injection de code malveillant dans l'application. L'utilisation de **requêtes paramétrées (Prepared Statements)** ou d'un ORM sécurisé permet de protéger la base de données contre les attaques de type SQL Injection.

Ensuite, l'application doit mettre en place une **gestion stricte des contrôles d'accès**. Chaque utilisateur doit uniquement pouvoir accéder aux ressources qui lui sont autorisées. Cela permet de prévenir les vulnérabilités liées au Broken Access Control, où un utilisateur pourrait accéder aux données d'un autre utilisateur en modifiant simplement certains paramètres dans les requêtes.

Il est également important de **protéger les fichiers et les répertoires sensibles** présents sur le serveur. Les documents internes ou les fichiers de configuration ne doivent pas être accessibles publiquement. L'accès à ces ressources doit être restreint et correctement configuré afin d'éviter toute fuite d'informations.

Par ailleurs, pour se protéger contre les attaques de type **Cross-Site Scripting (XSS)**, il est recommandé d'encoder correctement les données affichées dans les pages web et d'implémenter des mécanismes de sécurité tels que **Content Security Policy (CSP)**. Cela permet de limiter l'exécution de scripts malveillants dans le navigateur des utilisateurs.

De plus, la mise en place de **mécanismes de sécurité supplémentaires**, tels que la limitation des tentatives de connexion, la surveillance des activités suspectes et la journalisation des événements, peut contribuer à renforcer la sécurité globale de l'application.

Enfin, il est fortement recommandé d'effectuer **des audits de sécurité réguliers et des tests d'intrusion** afin d'identifier les nouvelles vulnérabilités et de corriger rapidement les failles de sécurité avant qu'elles ne puissent être exploitées.

Conclusion:

L'analyse de sécurité réalisée sur l'application **OWASP Juice Shop** a permis d'identifier plusieurs vulnérabilités importantes, notamment la **SQL Injection, le Cross-Site Scripting (XSS), l'exposition d'informations sensibles et des problèmes de contrôle d'accès**.

Ces failles montrent l'importance de mettre en place des mécanismes de sécurité efficaces lors du développement d'applications web. L'application de bonnes pratiques de développement sécurisé et le respect des recommandations de **OWASP** sont essentiels afin de protéger les systèmes et les données des utilisateurs contre les attaques.